

IT-Sicherheit

Prof. Dr. Tobias Straub
Masterprogramm Informatik

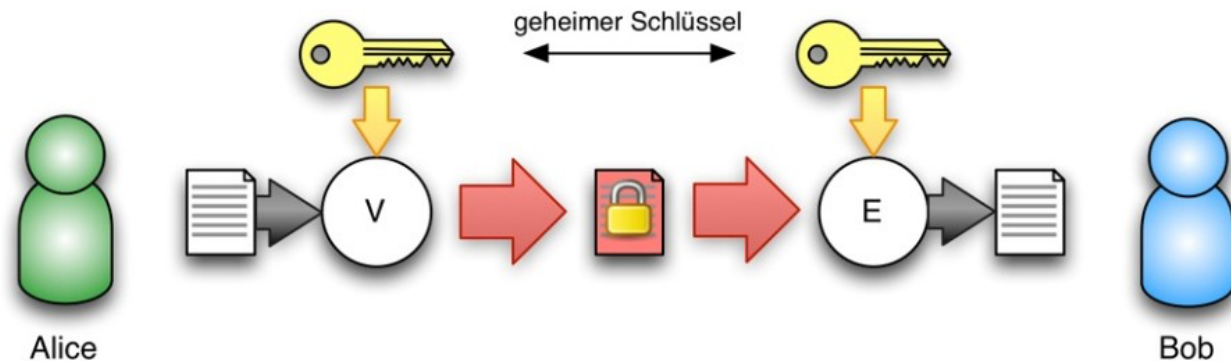
www.dhbw.de

© 2021 Tobias Straub – eine Nutzung der Unterlagen ist nur den Teilnehmer/innen und ausschließlich für Zwecke der Vorlesung gestattet, jegliche Weitergabe ist untersagt

Kryptographische Grundbausteine (Wiederholung)

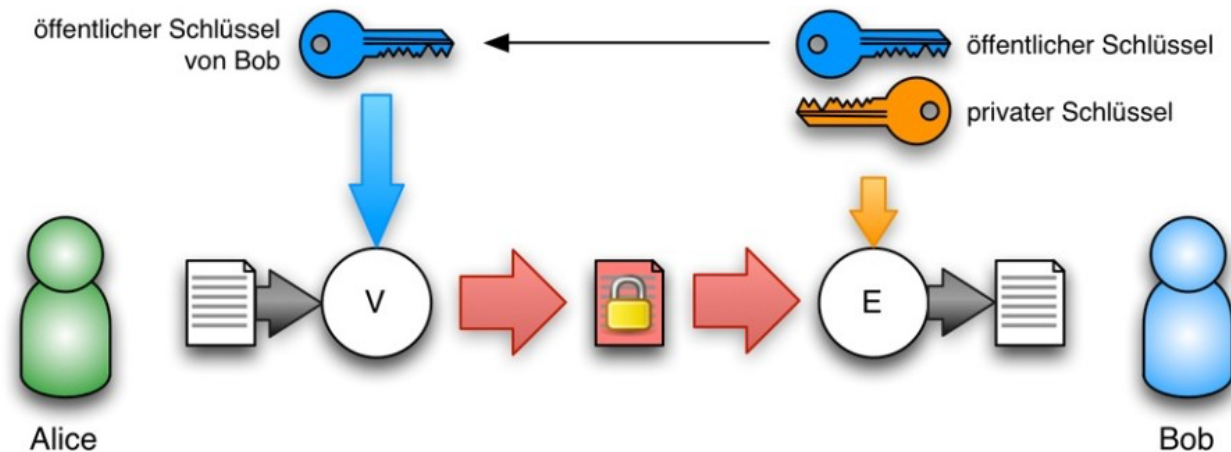
- **symmetrische Verschlüsselung** -> Vertraulichkeit
- **asymmetrische Verschlüsselung** -> Vertraulichkeit
(in der Praxis i.d.R. im Rahmen von hybrider Verschlüsselung zum Schlüsselaustausch)
- **kryptographische Hashfunktionen** -> Integrität
(Änderungen an Daten können durch Vergleich mit Original-Hashwert erkannt werden)
- **Message Authentication Codes** -> Integrität, Authentizität
(schützt vor unautorisierter Änderung und ist – nicht übertragbarer – Nachweis des Urhebers)
- **Digitale Signatur** -> Integrität, Authentizität
(schützt vor unautorisierter Änderung und ist übertragbarer Nachweis des Urhebers)

Symmetrische Verschlüsselung



- Kommunikationspartner Alice und Bob kennen beide den **geheimen Schlüssel**
- **Klartext** wird durch Verschlüsselung (V) in **Chiffre** überführt, Entschlüsselung (E) kehrt diese Operation wieder um
- ohne Kenntnis des Schlüssels kann Angreifer keine Information (außer der Länge) aus Chiffre ermitteln, "Durchprobieren" (brute force) aller Schlüssel unmöglich
- geheimer Schlüssel muss sicher gespeichert (zB. per Passwort geschützt oder Spezial-Hardware) und sicher ausgetauscht werden
- Konstruktion als **Blockchiffre** oder **Stromchiffre**
- typische Verfahren: AES (mit 128, 192 oder 256 Bit Schlüssel)

Asymmetrische Verschlüsselung (Public Key-Krypto.)

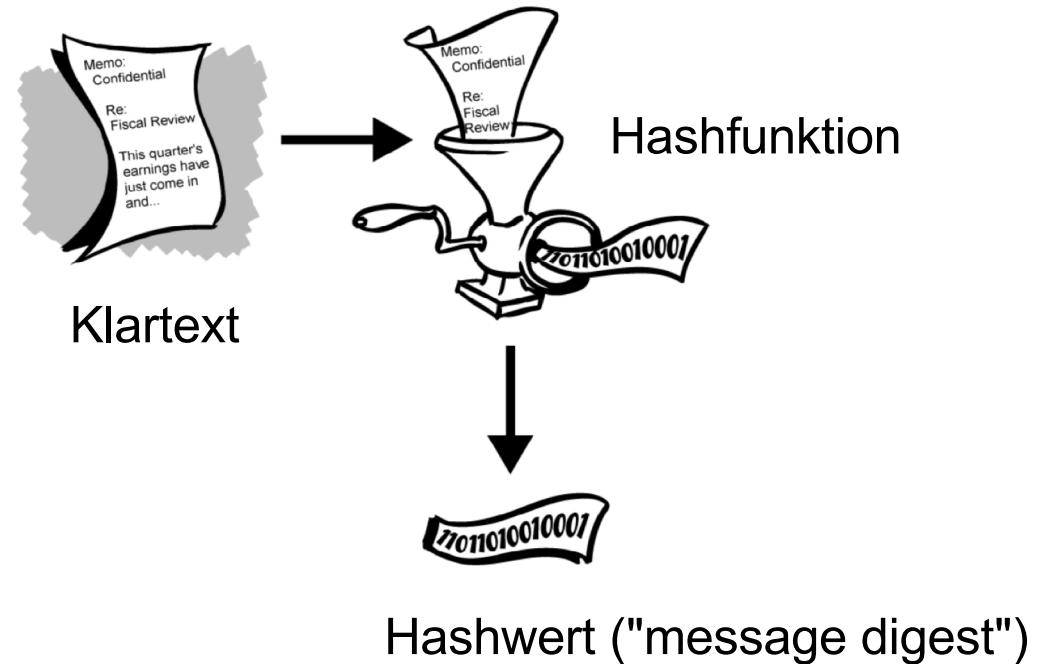


- Trennung der Operationen Ver- und Entschlüsselung:
 - Alice nutzt Bobs öffentlichen Schlüssel (**Public Key**) für Verschlüsselung
 - Bob nutzt seinen privaten Schlüssel (**Private Key**) für Entschlüsselung
- Private Key lässt sich aus Public Key nicht (mit vertretbarem Aufwand) bestimmen, brute force-Angriff unmöglich
- Private Key muss geschützt werden, Public Key kann öffentlich sein
- typische Verfahren: RSA (mit 2048, 4096 Bit Schlüssel), Kryptographie mit Elliptischen Kurven (kürzere Schlüssel: zB. 224, 256 Bit)

Kryptographische Hashfunktionen

Hashfunktion ist **Einweg-Funktion**:
beliebig lange Eingabe wird abgebildet auf
kurzen Hashwert (z.B. 256, 512 Bit)

- jede, auch nur minimale Änderung der Eingabe führt zu anderem Hashwert
- praktisch unmöglich:
 - **Kollision** finden (unterschiedliche Eingaben mit demselben Hashwert)
 - **Umkehrung** (finde Eingabe zu geg. Hashwert)
- typische Verfahren: SHA-256, SHA-512, SHA-3



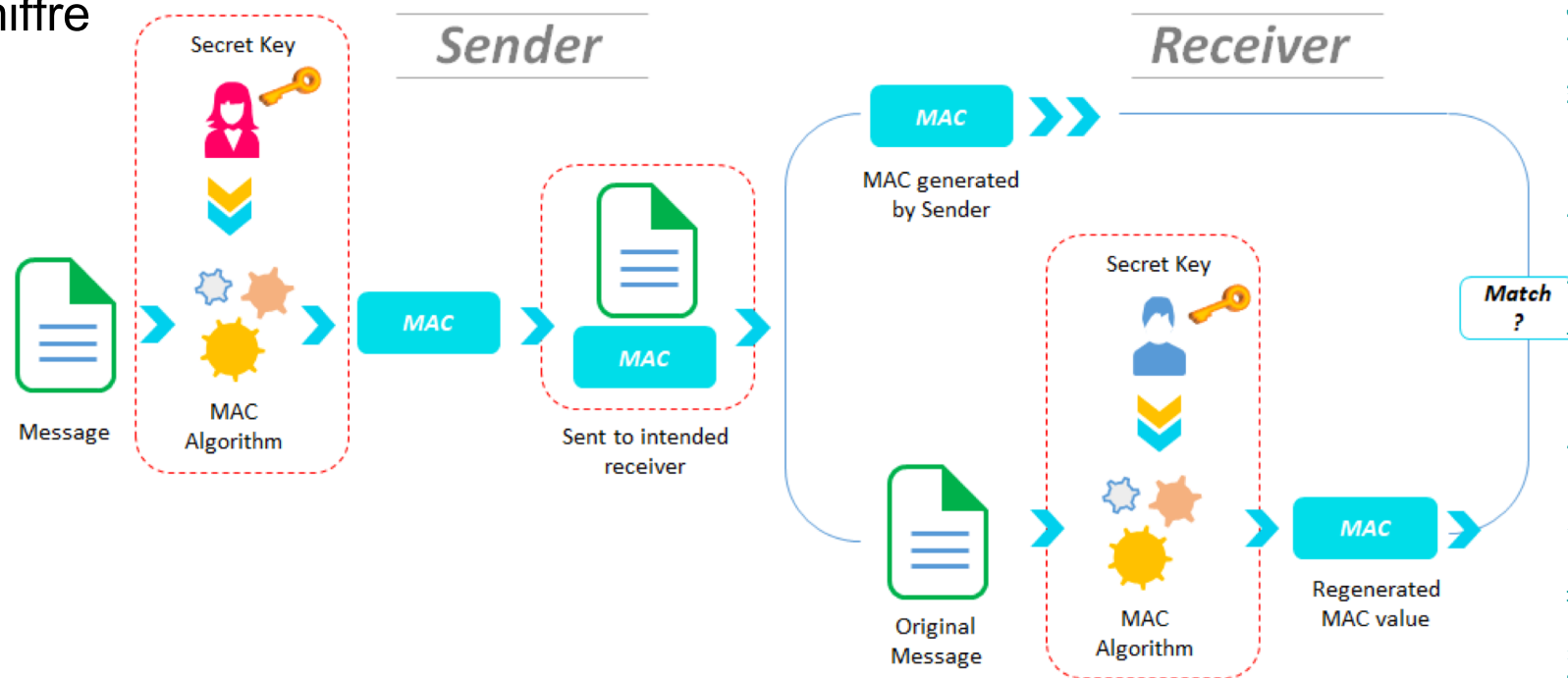
Message Authentication Code (MAC)

MAC ist **Einweg-Funktion**, die von **geheimem Schlüssel** abhängt

Sender und Empfänger müssen beide den Schlüssel kennen (können beide MAC erzeugen)

Konstruktion z.B. mittels:

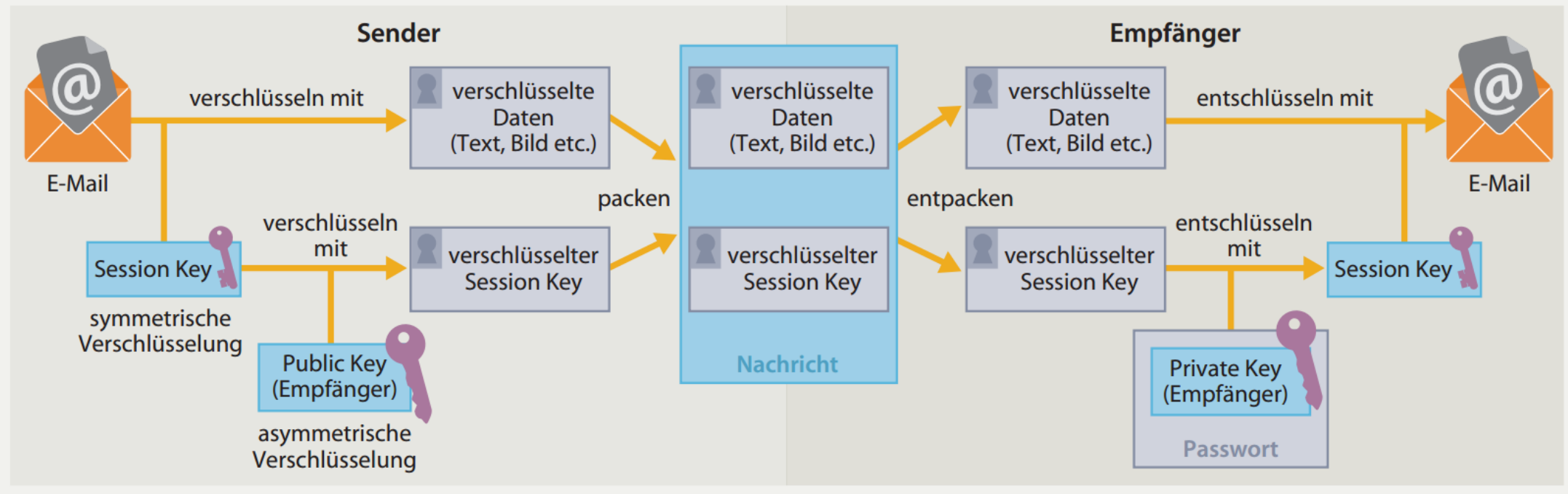
- Hashfunktion (HMAC)
- sym. Blockchiffre (CBC-MAC)



Beispiel: Hybridverschlüsselung bei E-Mail

Verschlüsseln

Beim Verschlüsseln von Mails wird die Nachricht mit einem Session Key symmetrisch chiffriert. Danach verschlüsselt PGP diesen Key mit dem öffentlichen Schlüssel des Empfängers (Hybridverschlüsselung).



[Abb: <https://www.heise.de/ct/artikel/Einfach-erklart-E-Mail-Verschlueselung-mit-PGP-4006652.html>]

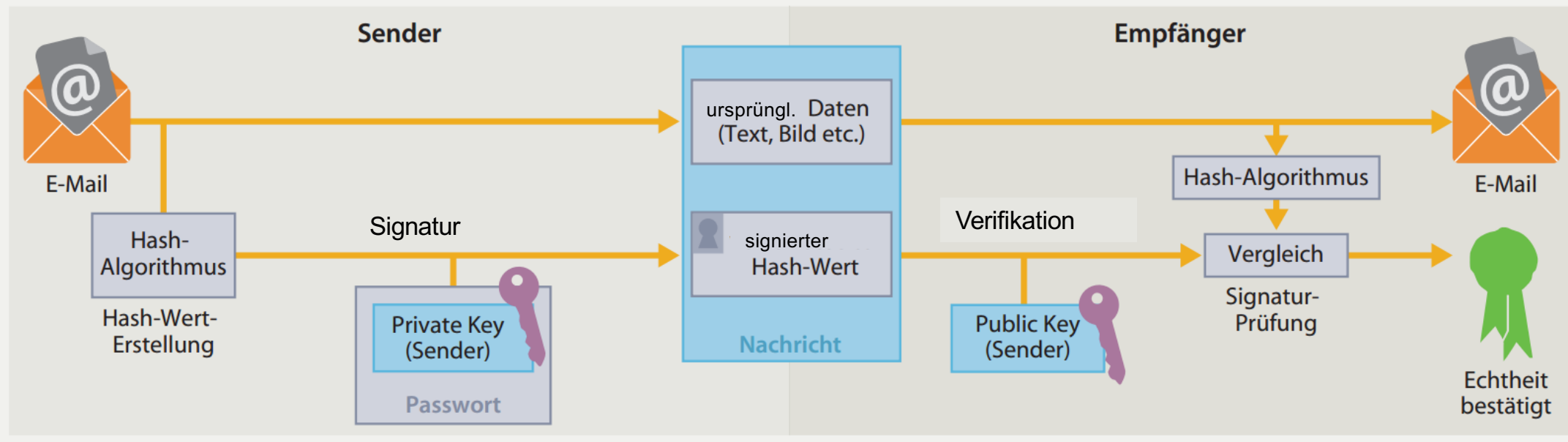
Digitale Signaturen

- bilden Prinzip der handschriftlichen **Unterschrift** nach
- Grundlage: **Asymmetrie der Operationen** bei Public Key-Kryptographie:
 - Signatur-Erstellung mit Private Key -> nur Schlüsselinhaber möglich (wie Entschlüsselung)
 - Signatur-Verifikation mit Public Key -> jedem möglich (wie Verschlüsselung)
jede Änderungen am Klartext macht **Signatur ungültig** -> damit erkennbar
- in der Praxis wird ein Klartext zuerst **gehasht** und dann der Hashwert signiert (somit lassen sich beliebige lange Eingaben effizient signieren)
- Eigenschaft **Nicht-Abstreitbarkeit**: nur Schlüsselinhaber kann Signatur erstellen, daher lässt sich Urheberschaft auch Dritten gegenüber nachweisen
- typische Verfahren: RSA, elliptische Kurven (ECC-DSA)

Beispiel: Signieren von E-Mails

Signieren

Die PGP-Signatur einer Mail enthält einen mit dem geheimen Schlüssel des Senders beglaubigten Hash-Wert. Der Empfänger kann die Signatur entschlüsseln und feststellen, ob die Mail unangetastet und der Sender authentisch ist.



[Abb: <https://www.heise.de/ct/artikel/Einfach-erklart-E-Mail-Verschlueselung-mit-PGP-4006652.html>, mit Änderungen]